OutOfRole: Plan, Changes and Findings

The Debugging Table · IBM Z Datathon 2026 · AI Secured: Innovation Without Exposure

October 17, 2026 (v4: early warning, case files, least privilege)

Purpose

This document records what we build on October 17 and 18, why the plan changed from our abstract, and what each step of the pre-event study found. Version 4 replaces the v3 plan, which was a retrospective fused ranking with the recommender as one of its signals.

The direction in one line: detection does not depend on the recommender. Each person is compared with their own history, day by day. Granite explains each alert from evidence that code picks and checks. The recommender suggests which access to pre-approve.

The pivot, stated openly. Our abstract promised recommender-based detection. Our tests showed that own-history baselines detect better, so the recommender moved to access advice.

Sources. Every number comes from `Verified_Numbers.md` (same folder), which names the script behind it; the scripts are in `reference/`. Roles, cut rules and the demo are in `../Build_Plan.md`; the plain-language explainer is `Team_Briefing.pdf`; the v3 study and its reviews are `OutOfRole_Feasibility.ipynb` and `codex_review/`.

Data and protocol. CMU SEI CERT Insider Threat Test Dataset (synthetic). r4.2: 1,000 staff, 70 insiders (leakers, job-hunters, sysadmins). r5.2: 2,000 staff, 99 insiders, adding snoopers who log into colleagues' computers. We train only before the cutoff (r4.2: June 1, 2010; r5.2: April 1, 2010) and drop the cutoff week. The answer key only grades; departure data is never used; settings were frozen on r4.2, then r5.2 was run unchanged.

The build plan

Part	What it does	Key evidence (r4.2 / r5.2)
1. Early warning (headline)	Replays the logs day by day. Each person's last 7 days are compared with each of their own training weeks; a feature is unusual when it beats all of them. The running score halves every 7 days; the top 20 people each day form the review list.	On the list before their last malicious action: **59 of 70 / 80 of 99**. Fair baseline (28-day window on the same 20-name list): 59 / 40, a tie on r4.2 and half of ours on r5.2. Chance about 3; random score 10.3 / 11.4
2. Granite case files	Code ranks each listed person's evidence "new to this person, rarest first" and gives the top items, each with an ID, to Granite. Granite returns only a summary label and fact IDs; code renders every fact, always shows the top-ranked evidence, and falls back to a fixed text on any other reply; an evidence-strength flag marks thin cases.	For insiders the daily list flags in time, using evidence up to the flag day: a real malicious item in the top 3 for **64% / 85%**, vs 49% / 51% for global rarity. Optional (post hoc): adding the top recommender item gives 78% / 85%

Part	What it does	Key evidence (r4.2 / r5.2)
3. Least-privilege advisor	A label-free tuned ALS recommender suggests which websites to pre-approve: each person's 20 most likely next sites. Anything else needs a request. A rule blocks any site that nobody in the company visited during training.	Next new sites caught in the top 20: 0.211 vs 0.145 for popularity / 0.190 vs 0.130, about **1.45 times**. Requests per person-month: 2.31 to 1.82 / 3.15 to 2.55. Only 28% / 42% of the extra grants were later used. Static coverage of the rule: 100% of wikileaks and keylogger-site visits
Support views	The v3 retrospective ranking over the whole test period, as a comparison view; and an experimental snooper view (weekly persistence of logins to unusual computers, discounted for people who already roamed)	Percentile P@20 1.00 / 1.00; frozen Stouffer finds 55 vs 44 / 43 vs 39 in 100 reviews. Snooper view: 27 to 30 of 30 snoopers in the top 100 (r5.2)

Everything runs on one LinuxONE server: Spark builds three tables (daily counts, person-computer-day, person-site-day), Granite runs through llama.cpp, and people appear as pseudonyms (U-017). Settings are fixed in `../Build_Plan.md`.

What changed from the abstract, and why

Abstract said	Now	Why (step)
Recommender-based detection: access the model would never suggest is flagged	Detection comes from own-history baselines; the recommender suggests which access to pre-approve	Own-history baselines detect better. As a detector, six recommender variants did no better than popularity, tuned or not (20); at predicting next sites, tuned, it beats popularity (16)
Later months replayed as a held-out "live" stream for scoring	A day-by-day replay with a 20-name daily list, graded on *when* each insider is flagged	The v3 ranking scored each person over the whole test period and could not say how early anyone was caught (19)
An AI on the same server explains why	Granite writes case files from evidence that code picks and checks	At flag time, "new to this person, rarest first" beats global rarity (0.64 / 0.85 vs 0.49 / 0.51); the recommender's surprise wins only on r4.2, through the job-hunters (18)
Files, computers and websites	Websites only, for the advisor	For computers nothing helps: 99.5% / 98.8% of new computers are someone else's personal PC (17)
Least privilege as one audience benefit	Access advice is one of the three parts	The tuned recommender cuts access requests at about the same static coverage (17)

v4 also retires two v3 positions: the verdict that the recommender was no better than popularity at predicting new sites (it came from untuned settings, Step 16), and the retrospective fused ranking as the default (now a support view, because the daily replay answers the analyst's question: who should I look at today?).

Results at a glance

Early warning (`early_warning_full.py`; `early_warning_simple.py` reproduces the counts):

Measure	r4.2 (70 insiders)	r5.2 (99 insiders)
On the list before their last malicious action ("in time")	**59** (84%)	**80** (81%)

Measure	r4.2 (70 insiders)	r5.2 (99 insiders)
Same, 28-day baseline on the same 20-name list (**the fair comparison**)	59 (84%)	40 (40%)
Same, 28-day baseline under the same decay rule (pre-registered comparison)	33 (47%)	28 (28%)
Same, random score with the same 20-name list	10.3	11.4
Same, chance (mean)	about 3	about 3
Same, pre-registered fusion detector	60 (86%)	54 (54.5%)
Median delay from the first labelled malicious day	1 day	9 days
Labelled malicious actions on later days than the flag (mean share)	54%	48%
New names per week (first-ever entrants) / distinct people per week	4.8 / 30.2	5.3 / 32.6

Against the fair baseline, which scores the 28-day window on each day's value alone and so churns the list at a similar rate, we tie on r4.2 and double it on r5.2. The headline holds against chance and the random score (whose list churns about 4 times faster). By attack type (in time, median delay in days): r4.2 leakers 25/30 (0), job-hunters 30/30 (11), sysadmins 4/10 (1); r5.2 leakers 26/29 (0), job-hunters 27/30 (21.5), sysadmins 2/10 (2), snoopers 25/30 (21.5). The leakers' 0 days is mostly prior listing (see the limits).

Case-file evidence (`evidence_ranking.py`): for insiders the daily list flags in time, using only evidence up to the flag day, "new to this person, rarest first" puts a malicious item in the top 3 for **0.64** (r4.2) and **0.85** (r5.2), against 0.49 / 0.51 for global rarity (+0.17 / +0.34) and 0.75 / 0.46 for the tuned recommender's surprise. The recommender wins on r4.2 only, through the job-hunters (C1: 0.33). C1's misleading rate is 0.09 / 0.02. An optional mixed rule (post hoc), the top 2 C1 items plus the top 1 recommender item, raises hit@3 from 0.66 to 0.78 (validator's evidence window; excluded from the build) on r4.2 (job-hunters 0.33 to 0.56) and keeps 0.85 on r5.2. This is the recommender's only measured evidence value. The 0.98 / 0.98 figure applies only to the top 100 of the retrospective full-period ranking (42 and 44 people, almost all leakers and sysadmins).

Least privilege (`least_privilege_full.py`, `recommender_als_simple.py`; normal staff, websites). Requests per person-month, then static coverage (malicious web events still needing approval), r4.2 / r5.2: own history only 2.31 / 3.15 and 71.0% / 90.1%; plus popularity top 20, 1.97 / 2.74 and 65.5% / 86.2%; plus tuned ALS top 20, **1.82 / 2.55** and 69.1% / 89.2%. ALS cuts the most requests. At matched cost (interpolated), its static coverage is 68.7% vs 60.4% for popularity (r4.2) and 85.9% vs 81.5% (r5.2). The advisor only suggests what to pre-approve: just 28% (r4.2) and 42% (r5.2) of the 20 extra grants were later used. "Static coverage" means the policy would have required approval for those events; it is not a measure of prevention. The new-to-company rule (`org_novel_sites.py`) covers every leaker wikileaks visit (69 on r4.2, 65 on r5.2) and every sysadmin keylogger-site visit (53, 38), at a cost to normal staff of 8 person-days across 5 people on r4.2 and none on r5.2.

The step ladder: the number at each step and the improvement

Steps 1 and 2 (Spark tables; a leakage check that ruled out departure data) have no score. "Before" is the reference named in the cell; "found" means expected insiders in the top 70; LR is logistic regression; MPR is mean percentile rank. Pairs of values are r4.2 / r5.2. Steps 3 to 15 quote the v3 notebook outputs.

Step	What we tried	Metric	Before	After	Change	Verdict
3	Personal baselines	found	none	R2 (28-day window): 38 / 36; P@20 1.00 / 0.90	the bar to beat	Baseline
4	Rare sites; recommender site surprise	found (r4.2)	R2 38	Rare sites 41 (r5.2: 8.1); ALS surprise 5 (AUC 0.71)	Rare +3, does not transfer; ALS -33	Rare kept as a family
5	Learned combiner	found (r4.2)	Behavior + rare 39	+ naive novelty 41; + ALS 45 (other seeds 44, 45)	+6	Stress test needed
6	More signals, second model	found (r4.2)	LR, all signals 45	+ ALS 49; gradient boosting 60	+4; +15	Stress-test it

Step	What we tried	Metric	Before	After	Change	Verdict
7	Hide job-hunters from training	job-hunters in top 100	none	Boosting 4; LR 5 to 7; label-free sum 16 of 30	Label-free +9 to +12	Not the headline
8	Weekly LOF (literature)	job-hunters in top 100	R2 5 of 30	12 to 13 of 30	+7 to +8	Slow-drift family
9	Recommender tweaks	found (r4.2)	ALS surprise 5	Site peer-of-item 17 (AUC 0.84)	+12	Candidate only
10	Own-history weekly percentile	found / AP (r4.2)	R2 38 / 0.728	39.4 / 0.666; P@20 1.00	+1.4 found	Core detector
11	Label-free family-first Stouffer	found / AP (r4.2)	R2 38 / 0.728	45 / 0.784 (all-detector Stouffer 39)	+7	Frozen for r5.2
12	r5.2, pipeline frozen	found / AP (r5.2)	R2 36 / 0.428	Stouffer 38 / 0.478; percentile AP 0.477	+2 found	Survives
13	Snooper signal	snoopers in top 100 (r5.2)	Naive new computers 10.9 of 30	Weekly persistence + roaming discount 27 of 30 (ownership, naive, ALS alike)	+16	Persistence, not ALS
14	Equal budget, 100 reviews	found in 100 reviews	R2 44 / 39	Stouffer 55 / 43; four queues 42 / 53	Stouffer +11 / +4	Fusion as v3 default
15	Recommender's own job, untuned	MPR, lower is better (r4.2)	Popularity 35.5	ALS 35.9	0.4 worse	Superseded by Step 16

Steps 16 to 20 come from the reference scripts (`Verified_Numbers.md`, sections 1 to 5); "at flag time" means insiders flagged in time, with evidence up to the flag day.

Step	What we tried	Metric	Before	After	Change	Verdict
16	Recommender, tuned without labels	recall@20, next new sites	Popularity 0.145 / 0.130; v3 setting 0.126 / 0.121	0.211 / 0.190	+0.066 / +0.060 over popularity (1.45x / 1.46x)	Real job found
17	Least-privilege advisor	requests per person-month	Own history 2.31 / 3.15	ALS top 20: 1.82 / 2.55 (popularity 1.97 / 2.74)	-21% / -19%; static coverage about the same (71.0% to 69.1%; 90.1% to 89.2%)	Build (role R4)
17b	New-to-company site rule	wikileaks and keylogger visits covered	none	100% on both releases	Cost: 8 person-days (r4.2), 0 (r5.2)	Build (role R4)
18	Evidence ranking for Granite	hit@3 at flag time	Global rarity 0.49 / 0.51	"New to you, rarest first" 0.64 / 0.85 (ALS 0.75 / 0.46; retrospective top-100 set: 0.98 / 0.98)	+0.17 / +0.34 over rarity	Build (role R3)
19	Early warning, daily replay	insiders in time	R2 on the same list 59 / 40 (same decay rule 33 / 28; random score 10 / 11; chance about 3 / 3)	Percentile 59 / 80 (pre-registered fusion 60 / 54)	0 / +40 over the fair baseline	Headline (role R2)
20a	Analyst feedback (AAD)	found in 100 reviews	Frozen Stouffer 55 / 43	57 / 42	+2 / -1 (noise: +0.2 ± 0.9)	Dropped
20b	Richer recommender items	web novelty found (r5.2)	Site rarity 11.4	Site x hour popularity 26.0; CF variants 22 to 26	+14.6 from context; CF adds nothing	Dropped

Step 20b used the v3 ALS setting. Re-run after label-free tuning (best web setting rank 128, alpha 0.1, regularization 10; site recall@20 0.232 / 0.202), person-level detection stays flat or worse (3.0 / 4.0 hits@70 on sites) and tuned ALS adds nothing to the logistic combiner (AP change -0.000 / -0.001, seed noise ±0.005). A better recommender is still not a detector. With job-hunters hidden from training, frozen fusion places 19 of 30 in the top 100, against 22 for feedback re-weighting (Step 20a) and 4 to 7 for trained combiners.

What external review changed

Codex (gpt-6.1-sol) reviewed the v3 notebook three times and the v4 claims once (`codex_review/`); we checked every point against the code and data before acting. **Rounds 1 to 3** found four real bugs (an unbalanced hold-one-attack-out test, a cutoff week that leaked test days into training, tie order deciding top-k counts, and an equal-budget comparison that graded the wrong fusion method). All were fixed and the notebook re-run. The fixes overturned three v3 claims: that the recommender belonged at the core because it added insiders to a trained combiner, that collaborative filtering "forgives" a colleague's computer, and that specialist queues beat one fused list. Those corrections started the move that v4 completes: the recommender left detection.

Round 4 (October 17, on v4) changed seven claims, each reflected above: evidence is graded only on what was known at the alert (0.64 / 0.85, not 98%); the fair baseline leads the early-warning comparison; the leakers' 0-day delay is mostly prior listing; the advisor only suggests pre-approvals, and its coverage is static; hidden job-hunters (frozen fusion 19 of 30); two answer parsers now read only each insider's own rows (numbers unchanged); and the pivot is stated.

An independent validator found no look-ahead and no label leakage in any scoring code; a random-score control and a one-month-later cutoff both left the headline intact. Most headline numbers were re-run by independent code, and the early-warning and evidence protocols were written before any result.

Honest limits

- **A replay, not a live system.** We replay past logs day by day with no look-ahead. Say "flags insiders while they are still active", never "real-time production system". About half of each insider's labelled malicious actions (54% / 48%) came on later days than the flag: remaining opportunity, not prevention.
- **The fair baseline ties us on r4.2.** On the same 20-name list, the 28-day baseline flags 59 of 70, as we do; our gain is on r5.2 (80 vs 40).
- **Missed and late attacks.** Two-day sysadmin sabotage: 4 of 10 and 2 of 10. Median delay for job-hunters is 11 and 21.5 days, and for snoopers 21.5 days.
- **Leakers look faster than they are.** Their 0-day median is mostly prior listing: only 7 of 30 and 15 of 29 were newly flagged. Counting only insiders not listed in the 14 days before their first malicious action gives 38 and 67 in time. Most leakers (25 of 30, 24 of 29) show unlabelled after-hours USB activity in the week before their labelled start.
- **Analyst load.** Normal staff hold 60% / 63% of list slots; 30.2 / 32.6 distinct people are on the list each week.
- **The advisor is a suggestion list.** Only 28% / 42% of its extra grants were later used, and its coverage is static, not prevention.
- **Evidence strength is not a verdict.** 80 to 92% of flagged normal staff have weak evidence, but so do 44 to 56% of insiders flagged in time; never use it to dismiss anyone.
- **Disclosures.** The pre-registered primary comparison (fusion vs the 28-day baseline) passed on both releases (McNemar $p < 0.001$), but the percentile headline was picked after seeing results; the pre-registered fusion flagged 60 of 70 and 54 of 99 (54.5%). Each train cutoff was set to precede every attack, which used the labels. `least_privilege_full.py` trains through the day before the cutoff instead of dropping the cutoff week (not leakage: every attack starts after it). Request counts keep leavers in the denominator for both policies, so the -21% / -19% holds.
- **Data and untested pieces.** CERT is synthetic, with insiders 5 to 7% of staff. Granite on LinuxONE is untested; the snooper view needs an untouched test.